ZYROO CYBERSECURITY INTERNSHIP

Week 7–8 Capstone

Penetration Test & Security Assessment Report

Prepared by: **Anas**

Testing Platform: Kali Linux

Engagement Type: Authorized, isolated internal training lab

Targets: Metasploitable2 (192.168.10.4) & OWASP Juice Shop (127.0.0.1:3000)

Report Date: October 2026

GitHub Repository: github.com/Aans9988/Zyro-cyber-security-week-7_8

This report documents an authorized penetration test conducted entirely within the isolated Zyroo internship lab environment. No external, production, or third-party systems were accessed or tested.

1. Executive Summary

An authorized security assessment was carried out against two isolated lab targets: the Metasploitable2 virtual machine (representing an internal network host) and the OWASP Juice Shop web application (representing a customer-facing web service). The objective was to simulate how a real attacker could discover and exploit weaknesses in these systems, and then to verify that at least one weakness could be properly fixed.

The assessment found one **Critical**-severity issue: the FTP service on the Metasploitable2 host (vsftpd 2.3.4) contained a known backdoor that allowed an attacker to obtain a full command shell with **root-level** privileges, without needing any valid username or password. This is the most severe possible outcome of a network compromise — complete, unauthenticated control of the machine.

Network scanning also surfaced several legacy, insecure services (unencrypted Telnet, an SMB service configured with guest access and signing disabled) that increase the host's overall attack surface and are flagged for remediation, though they were not individually exploited during this engagement.

On the web application side, baseline testing of the Juice Shop application identified configuration-level observations — a wildcard Cross-Origin Resource Sharing (CORS) header and the absence of several recommended HTTP security headers — that are good practice to fix but did not, on their own, demonstrate a working exploit or data exposure during this test.

The Critical finding was remediated during the engagement: the vulnerable FTP service was disabled, and a follow-up scan confirmed the port was closed. This closes the most dangerous attack path identified in the assessment. Remaining observations are prioritized in the remediation roadmap in Section 9.

2. Scope & Rules of Engagement

Item	Detail
In-scope targets	Metasploitable2 VM (192.168.10.4); OWASP Juice Shop web app (127.0.0.1:3000, Docker container)
Attacker platform	Kali Linux (host: kila)
Permitted techniques	Network/service scanning (Nmap), web request testing (curl), known-exploit verification (Metasploit Framework)
Explicitly out of bounds	Any public IP address, third-party system, or production service outside the isolated Zyroo lab network
Environment	Fully isolated training lab; all targets run as local VMs / Docker containers on the tester's own machine

3. Methodology

The engagement followed a standard attacker lifecycle, re-running and consolidating scanning work from earlier weeks of the internship into one connected assessment:

- **Reconnaissance & Scanning** — service/version discovery with Nmap against both targets

- **Vulnerability Identification** — matching discovered service versions and web responses against known weaknesses
- **Exploitation** — verifying at least one finding end-to-end using the Metasploit Framework
- **Privilege Escalation / Impact Confirmation** — confirming the access level obtained (root)
- **Post-Exploitation Impact Analysis** — assessing what an attacker could do with that access
- **Mitigation & Retest** — applying a fix and re-scanning to prove the issue was closed

4. Reconnaissance & Scanning Results

4.1 Metasploitable2 (192.168.10.4) — Nmap `-sV -sC` scan:

Port	Service	Version / Notes
21/tcp	ftp	vsftpd 2.3.4 — **contains known backdoor** (see Finding 1)
22/tcp	ssh	OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp	telnet	Linux telnetd — unencrypted cleartext protocol
25/tcp	smtp	Postfix smtpd
SMB	samba	Samba 3.0.20-Debian; guest account access; message signing disabled (dangerous default)

4.2 OWASP Juice Shop (127.0.0.1:3000) — baseline web reconnaissance:

- Application reachable and responding normally (HTTP 200 on root, REST API endpoints functional)
- Response headers captured and reviewed for security hardening gaps (Section 6.2)
- CORS behavior tested by sending a crafted `Origin` header against the product-search API
- Empty/invalid login attempts correctly rejected with HTTP 401 (no authentication bypass observed in this baseline test)
- Built-in challenge catalogue enumerated (116 total challenge definitions) to confirm which vulnerability classes the target application is designed to exercise: Sensitive Data Exposure, Injection, Broken Access Control, Broken Authentication, XSS, CSRF, SSRF and others — consistent with the SQLi/XSS/CSRF and Broken Access Control/IDOR/JWT areas scoped in earlier weeks of this internship

5. Consolidated Findings Summary

#	Finding	Severity	Asset
1	vsftpd 2.3.4 backdoor — unauthenticated root shell	**Critical**	Metasploitable2 (FTP, port 21)
2	Unencrypted Telnet service exposed	**Medium**	Metasploitable2 (port 23)
3	SMB guest access with message signing disabled	**Medium**	Metasploitable2 (Samba)
4	Wildcard CORS header (Access-Control-Allow-Origin: *)	**Informational**	Juice Shop (REST API)
5	Missing CSP / Referrer-Policy / Permissions-Policy headers	**Low**	Juice Shop (HTTP response headers)

Note: Findings 2–3 are configuration weaknesses identified via service/version scanning. In keeping with sound testing practice, version detection alone is not treated as proof of exploitability — only Finding 1 was verified end-to-end with a working exploit.

6. Detailed Findings

6.1 Finding 1 — vsftpd 2.3.4 Backdoor (Unauthenticated Root Shell)

Severity	**Critical**
Affected Asset	Metasploitable2 — 192.168.10.4:21 (FTP)
CVE / Reference	OSVDB-73573 — malicious backdoor planted in the vsftpd-2.3.4.tar.gz source archive (Jun 30 – Jul 3, 2011)
Technique	Metasploit module exploit/unix/ftp/vsftpd_234_backdoor

Evidence:

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > exploit
[*] 192.168.10.4:21 - Banner: 220 (vsFTPd 2.3.4)
[+] 192.168.10.4:21 - UID: uid=0(root) gid=0(root)
[*] Command shell session 1 opened (192.168.10.13:33517 -> 192.168.10.4:6200)
whoami -> root
```

Impact: This grants a remote attacker a full, unauthenticated command shell running as **root** — the highest privilege level on a Linux system. From this foothold, an attacker could read, modify, or delete any file; create backdoor accounts; pivot to other systems on the same network; or use the host to launch further attacks. No privilege escalation step was required, since the backdoor grants root directly.

Remediation: Keep the FTP service disabled on this host. If file transfer is required, use a maintained, supported service (e.g. SFTP/SSH) instead of the vulnerable vsftpd 2.3.4 build, and restrict network exposure with firewall rules.

Mitigation Verification (Before / After):

`Before: nmap -sV -p 21 192.168.10.4 →` **`21/tcp open ftp vsftpd 2.3.4`**
`After: nmap -sV -p 21 192.168.10.4 →` **`21/tcp closed ftp`**

The retest confirms the service was taken offline and the port is no longer reachable, closing this attack path. (This reduces exposure by removing the running service; it does not patch the underlying vulnerable binary, which should still be removed

or upgraded if FTP is ever reinstated.)

6.2 Finding 2 & 3 — Legacy/Insecure Network Services

Evidence: Nmap service detection identified Telnet (port 23, unencrypted) and a Samba/SMB service configured for guest-level access with message signing disabled — a combination flagged by Nmap itself as 'dangerous, but default'.

Impact: Telnet transmits credentials and session data in plaintext, making them trivial to intercept on a shared network. Guest SMB access with signing disabled increases the risk of unauthorized access and man-in-the-middle tampering of SMB traffic.

Remediation: Disable Telnet in favor of SSH; disable guest access on SMB shares and enforce SMB message signing.

6.3 Observation 4 — Wildcard CORS Header (Juice Shop)

Evidence: Requests to the product-search REST endpoint, including with a crafted untrusted `Origin` header, returned `Access-Control-Allow-Origin: *` in every tested response.

Impact: A wildcard CORS policy allows any website to read this API's responses from a victim's browser. In this baseline test the affected endpoint only returned public product data, so no sensitive-data exposure was demonstrated — but the same policy applied to a more sensitive endpoint could leak user data. This is recorded as Informational pending endpoint-specific review.

Remediation: Review CORS requirements endpoint by endpoint and restrict Access-Control-Allow-Origin to a list of trusted origins instead of a wildcard.

6.4 Observation 5 — Missing HTTP Security Headers (Juice Shop)

Evidence: The application's root response included `X-Content-Type-Options` and `X-Frame-Options`, but did not include `Content-Security-Policy`, `Referrer-Policy`, `Permissions-Policy`, or `Strict-Transport-Security`.

Impact: These are defense-in-depth headers; their absence does not by itself constitute an exploitable vulnerability, but it reduces the browser-side protections available against XSS, clickjacking and data-leakage style attacks.

Remediation: Define and deploy a Content-Security-Policy, Referrer-Policy and Permissions-Policy appropriate to the application, and enforce HSTS once served over HTTPS.

7. Post-Exploitation Impact Summary

Chaining the confirmed finding with the broader reconnaissance picture shows a realistic attack narrative: a remote, unauthenticated attacker scanning the network would discover the FTP banner on Metasploitable2 (Finding 1), exploit it directly to obtain a root shell with zero prior access, and from that position could pivot across the network using the plaintext Telnet service and the weakly configured SMB share to extend access to other hosts or harvest credentials. On the web front, the configuration gaps identified in Juice Shop (wildcard CORS, missing hardening headers) would lower the bar for a follow-on client-side attack if combined with an injection or authentication weakness elsewhere in the application — the categories of issue this target is specifically built to contain (SQL Injection, XSS, CSRF, Broken Access Control, Broken Authentication), per its own challenge catalogue. The single most damaging confirmed outcome of this engagement remains the root-level compromise of Metasploitable2 via Finding 1.

8. Overall Risk Summary & Prioritized Remediation Roadmap

Priority	Action	Addresses
1	Keep vulnerable FTP service disabled; remove/upgrade vsftpd if file transfer is needed	**Finding 1 (Critical)**
2	Disable Telnet; migrate to SSH-only remote access	**Finding 2 (Medium)**
3	Disable SMB guest access; enforce SMB signing	**Finding 3 (Medium)**
4	Restrict CORS to trusted origins on a per-endpoint basis	**Observation 4 (Informational)**
5	Add CSP, Referrer-Policy, Permissions-Policy, HSTS headers	**Observation 5 (Low)**

9. Scope Limitations

Testing was limited to the specified isolated training systems and the requests recorded during this engagement. The Juice Shop assessment consisted of baseline configuration and behavior checks rather than a full exploitation pass against every challenge category the application contains; no claim is made that every built-in challenge was solved or every endpoint tested. Results should not be generalized beyond this lab environment or to any production system.

10. Conclusion

This engagement successfully demonstrated a complete attacker lifecycle against the Metasploitable2 target: reconnaissance identified an exposed, outdated FTP service; vulnerability research matched it to a known Critical backdoor; exploitation obtained a full root shell with no authentication required; and the issue was then mitigated and independently re-verified as closed. This represents the strongest and most conclusive result of the assessment.

The Juice Shop component of the engagement produced useful configuration-level observations (wildcard CORS, missing security headers) but did not, within the scope of this capstone's testing, confirm an actively exploitable vulnerability on its own. Further, deeper authorized testing against individual Juice Shop endpoints — building on the SQL Injection, XSS, CSRF, and Broken Access Control work carried out in earlier weeks of this internship — is recommended before this target is considered fully assessed.

Taken together, the internship's eight weeks demonstrate the full offensive security lifecycle: lab setup and reconnaissance, vulnerability scanning, manual web application testing, exploitation with Metasploit, privilege escalation, and finally professional reporting paired with real, verified remediation.

Appendix A — Tools, Technologies & Repository

GitHub Repository (submission): https://github.com/Aans9988/Zyro-cyber-security-week-7_8.git

- Kali Linux — attacker platform
- Nmap 7.95 — service/version discovery and scripted scanning
- Metasploit Framework — exploit verification (exploit/unix/ftp/vsftpd_234_backdoor)
- curl — HTTP/API request testing and header inspection against Juice Shop
- OWASP Juice Shop — modern vulnerable web application target
- Metasploitable2 — intentionally vulnerable Linux network target

Appendix B — Evidence Index

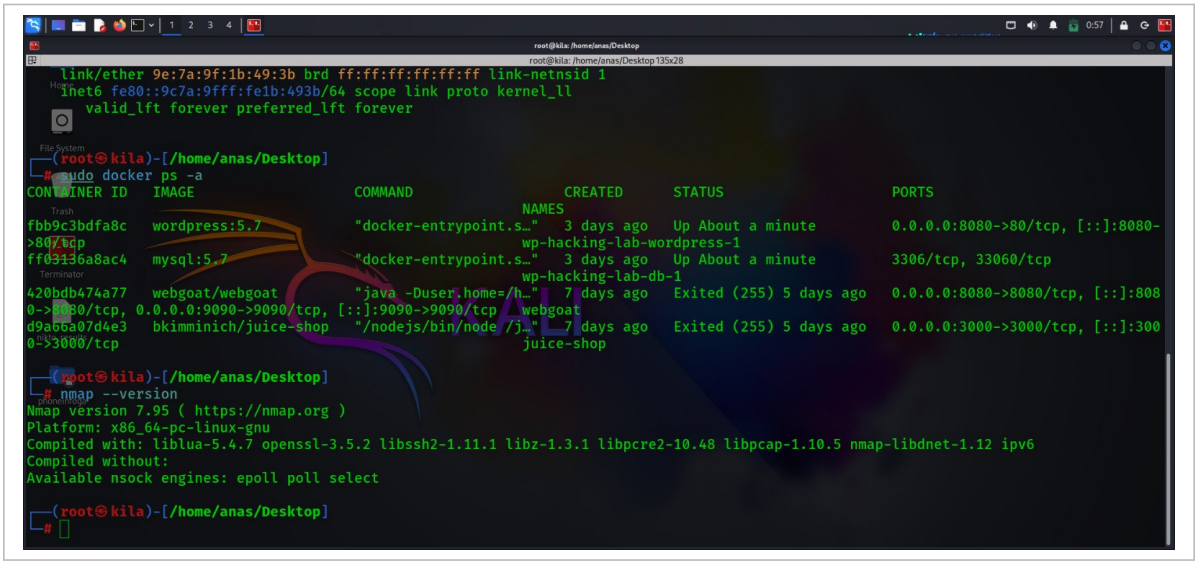
All raw command output referenced in this report was captured to text files in the engagement evidence folder, including:

- metasploitable_scan.txt — full Nmap -sV -sC service scan of 192.168.10.4
- before_mitigation.txt / after_mitigation.txt — FTP port state before and after remediation
- root_verification.txt — exploitation session output confirming uid=0(root)
- juice_shop_scan.txt, juice_shop_headers_full.txt, juice_shop_cors_test.txt — Juice Shop recon and header evidence
- juice_shop_login_baseline.txt — authentication baseline test (HTTP 401 on invalid/empty credentials)
- juice_shop_challenges.json — enumerated built-in challenge catalogue (116 entries) used to scope vulnerability categories

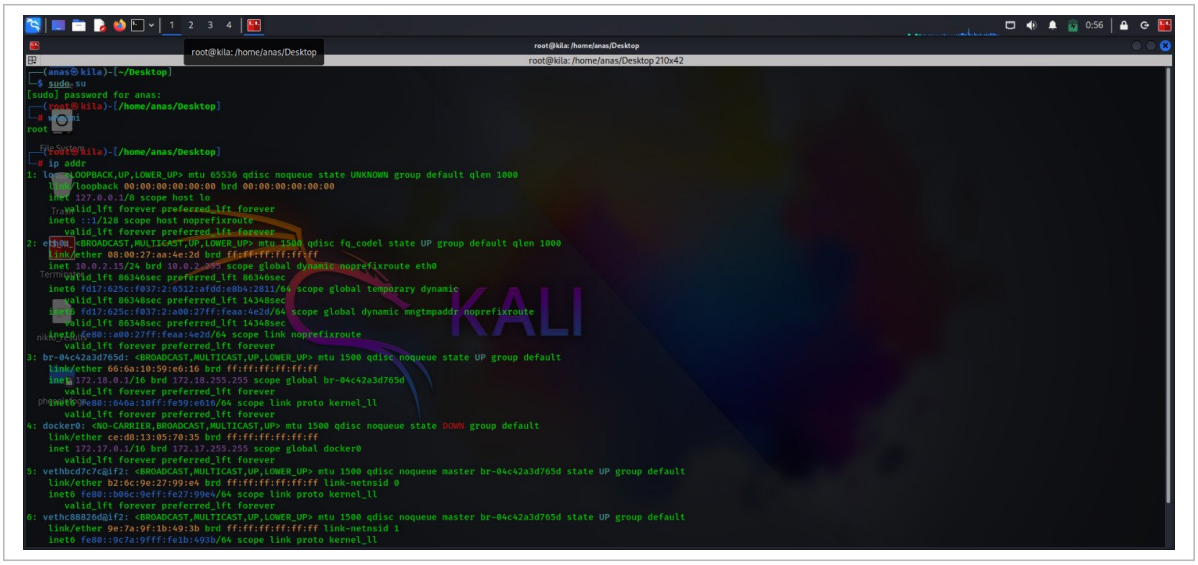
Appendix C — Evidence Screenshots

The following terminal and browser captures were taken directly during the engagement and correspond to the evidence files listed in Appendix B.

C.1 Lab Setup & Target Discovery

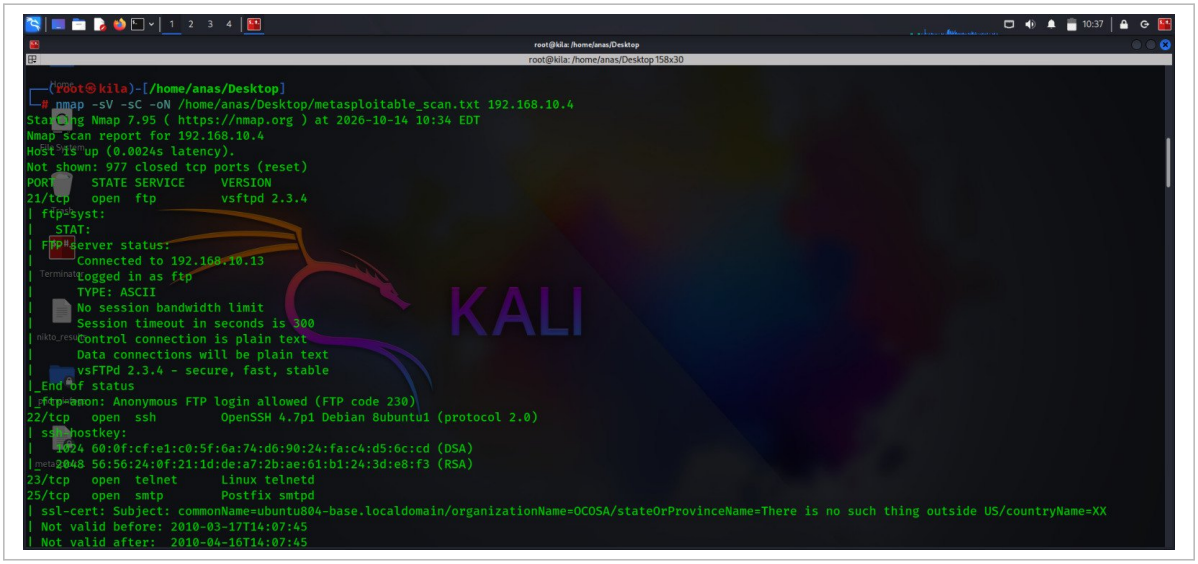


Lab containers enumerated (docker ps -a) and Nmap 7.95 confirmed on the Kali attacker host.

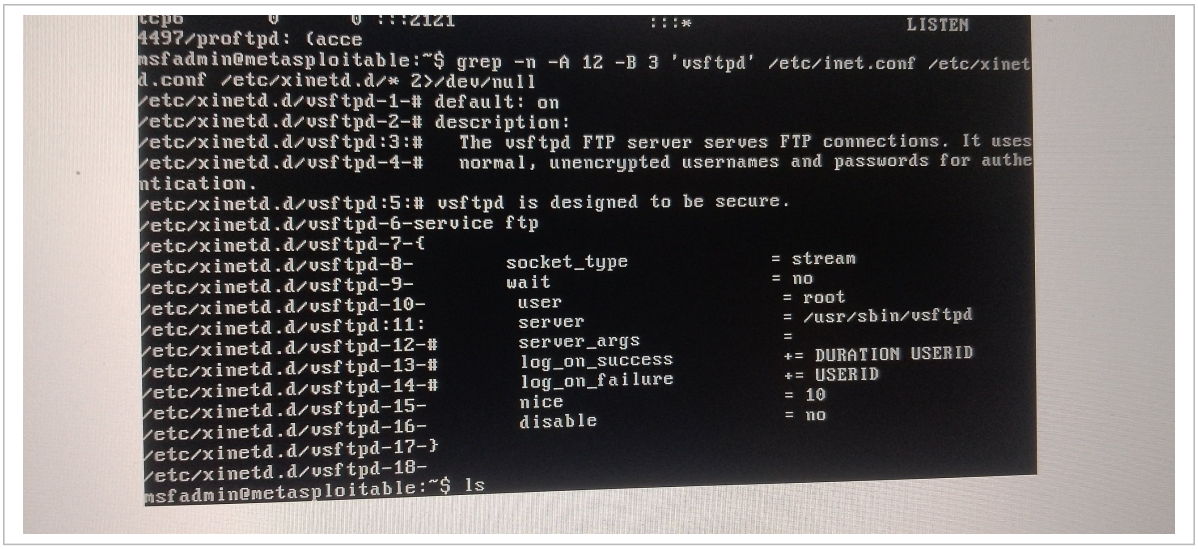


Attacker network interfaces (ip addr) confirming connectivity to the isolated lab network.

C.2 Reconnaissance & Scanning

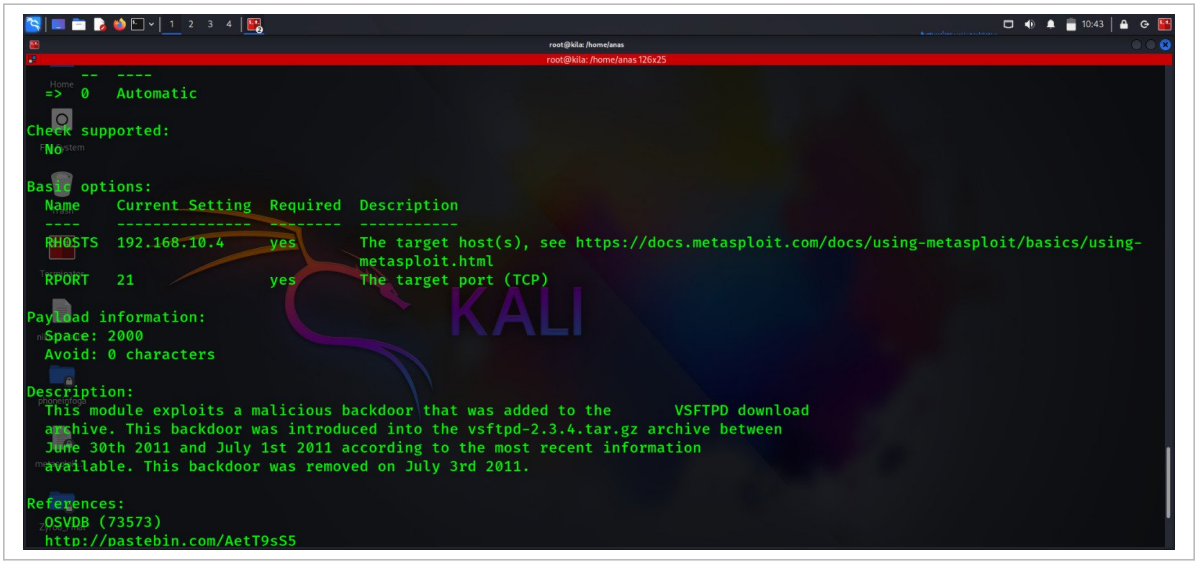


Nmap -sV -sC scan of Metasploitable2 (192.168.10.4): ports 21/ftp (vsftpd 2.3.4), 22/ssh, 23/telnet, 25/smtp identified.

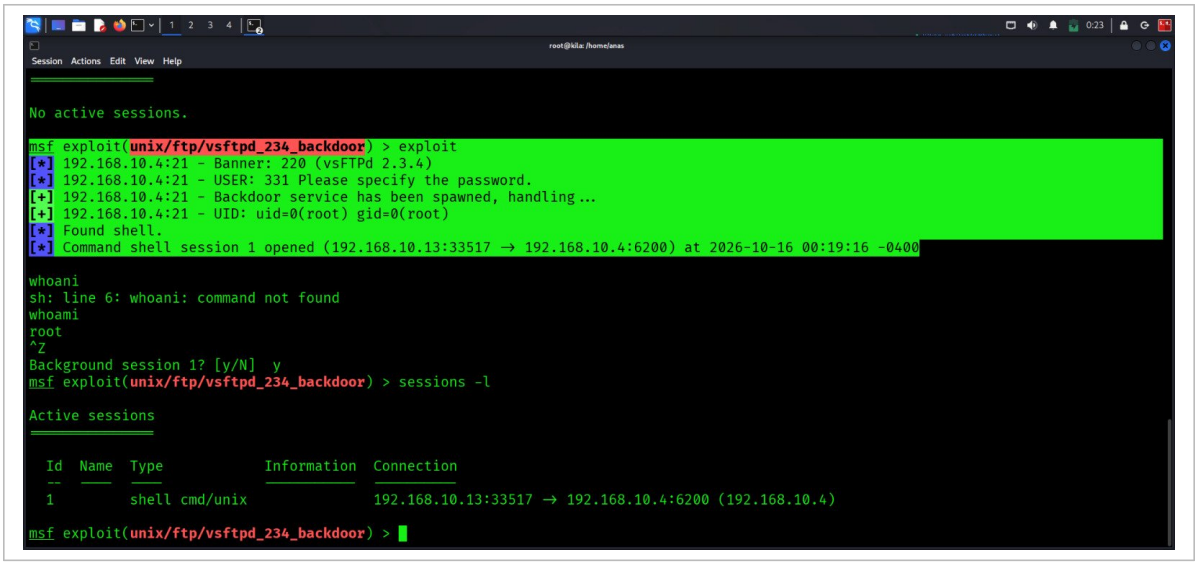


vsftpd service configuration confirmed on the target via xinetd, validating the FTP service identified by the scan.

C.3 Exploitation

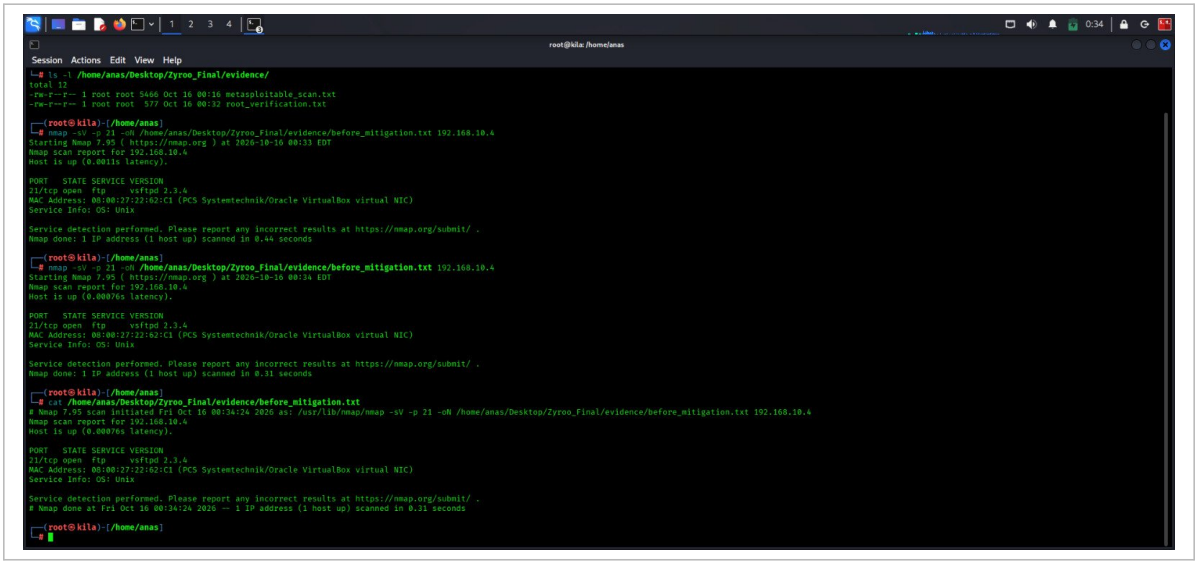


Metasploit module exploit/unix/ftp/vsftpd_234_backdoor loaded and configured against the authorized target (RHOSTS 192.168.10.4, RPORT 21).

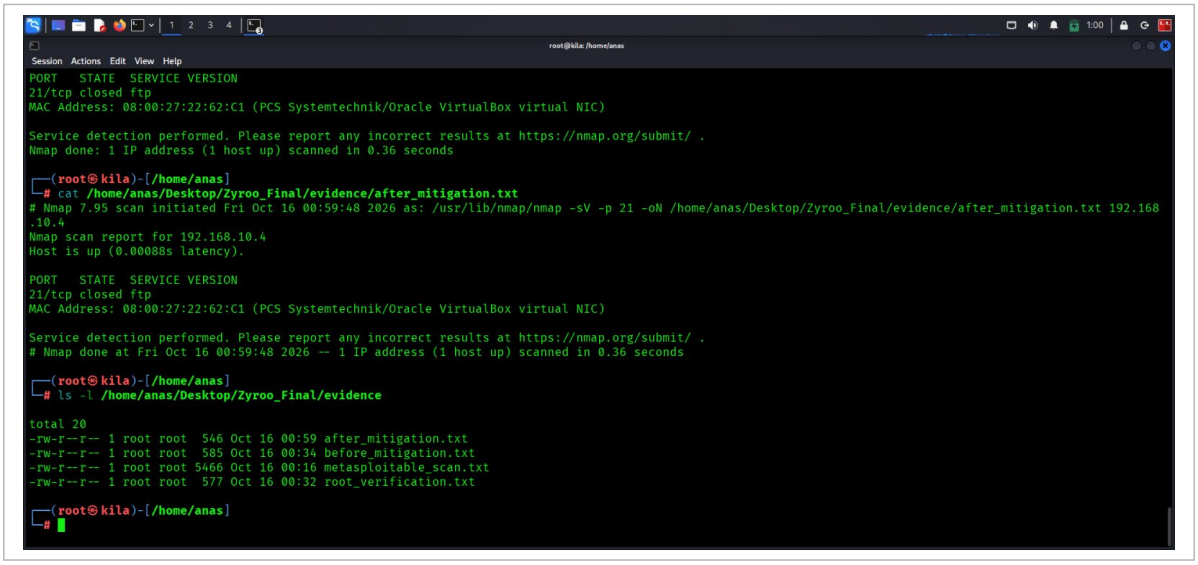


Exploit executed successfully — command shell session opened; whoami and UID confirm root-level access (uid=0(root) gid=0(root)).

C.4 Mitigation & Verification

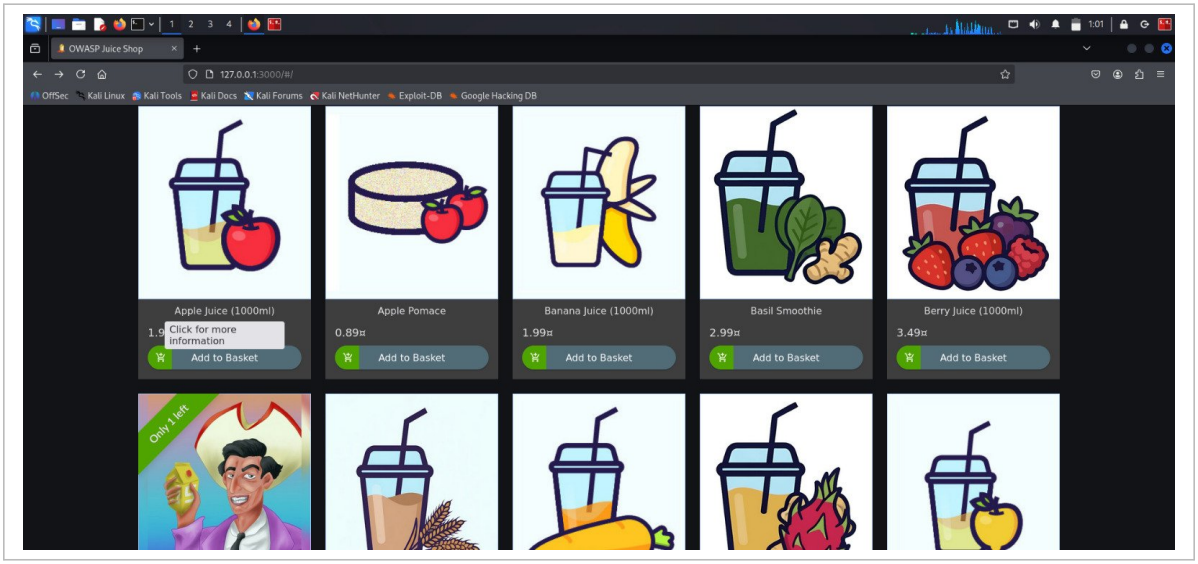


Before mitigation: targeted scan confirms port 21/tcp open, vsftpd 2.3.4.

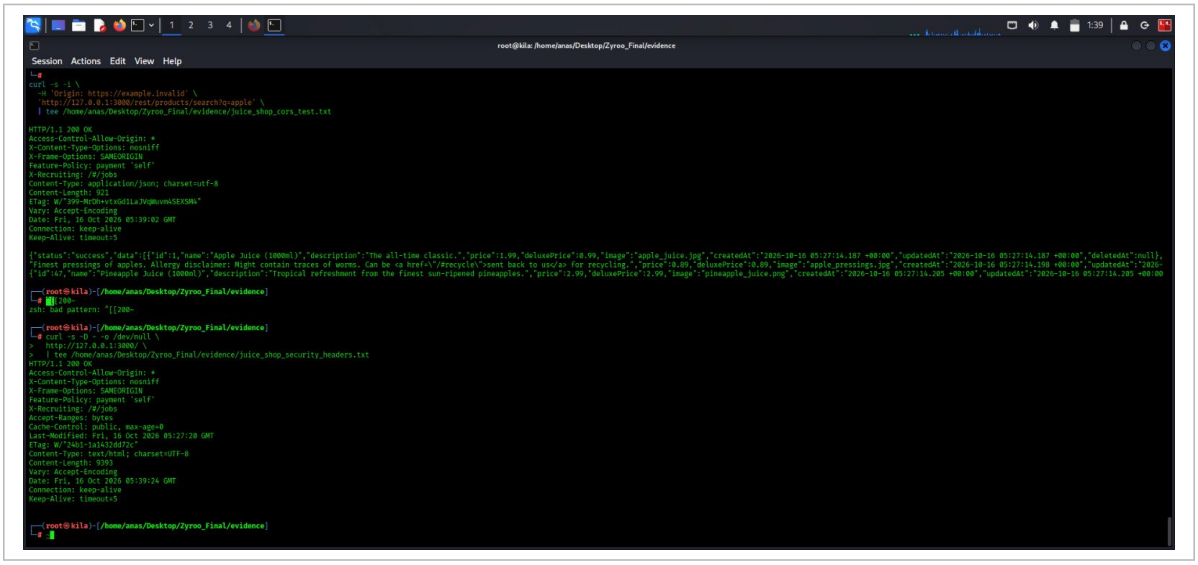


After mitigation: repeat scan confirms port 21/tcp closed — the vulnerable service was successfully disabled and the fix verified.

C.5 Juice Shop Web Application Testing



OWASP Juice Shop target reachable and serving its product catalogue at 127.0.0.1:3000.



CORS test: a crafted untrusted Origin header still receives Access-Control-Allow-Origin: * in the response, alongside the captured security header baseline.